

Artist's Way Journey

Smart Contract Security Review

Taylor Haun

December 5, 2024

Table of Contents

- Protocol Summary
- Disclaimer
- Risk Classification
- Audit Details
- Executive Summary
- Findings
- Proof of Concept Results

Protocol Summary

Artist's Way Journey is an on-chain tracking system for Julia Cameron's 12-week creative program, deployed on Base L2. The protocol uses:

- **ArtistWayJourney.sol** - Main ERC-1155 contract for tracking morning pages, artist dates, streaks, and achievements
- **ArtistWayToken.sol** - ERC-20 reward token minted when users complete activities
- **DummyVerifier.sol** - Placeholder ZK verifier (Phase 1)
- **TokenIds.sol** - Library for token ID management

Token Reward Structure:

Activity	BASIC Tier	VERIFIED Tier (10x)
Morning Page	10 tokens	100 tokens
Artist Date	50 tokens	500 tokens
Weekly Badge	200 tokens	200 tokens
Streak Badge	300 tokens	300 tokens
Journey Complete	1000 tokens	1000 tokens
Lifetime Achievement	400 tokens	400 tokens

Disclaimer

The security researcher makes all effort to find as many vulnerabilities in the code in the given time period, but holds no responsibilities for the findings provided in this document. A security review is not an endorsement of the underlying business or product. The review was time-boxed and focused solely on the security aspects of the Solidity implementation.

Risk Classification

		Impact		
Likelihood	High	High	Medium	Low
	Medium	H	H/M	M
	Low	H/M	M	M/L
		M	M/L	L

We use the CodeHawks severity matrix to determine severity.

Audit Details

Repository	artist-way-v5.1
Commit Hash	1836a9b
Review Period	December 5, 2024
Methods	Manual code review, Foundry testing

Scope

Contract	SLOC	Purpose
ArtistWayJourney.sol	~650	Main ERC-1155 journey tracking
ArtistWayToken.sol	~85	ERC-20 reward token
DummyVerifier.sol	~50	Placeholder verifier
IVerifier.sol	~45	Verifier interface
TokenIds.sol	~200	Token ID management

Roles

Role	Description
Owner	Contract deployer; can set verifier, URI, and record activities for users
Minter	ArtistWayJourney contract (authorized to mint ERC-20 tokens)
User	Can start journeys, record activities, earn tokens and achievements

Executive Summary

This security review identified **critical token farming vulnerabilities** in the Artist’s Way Journey contracts. The most severe issue allows users to **complete an entire 12-week journey and earn all rewards in a single transaction** by exploiting the lack of timestamp validation.

All findings were verified with Foundry proof-of-concept tests demonstrating:

- **20,950 tokens** farmed in a single transaction
- **60-day streak** achieved instantly
- **7x token advantage** over legitimate users

The core vulnerability: `unixDay` and `timestamp` parameters are user-supplied with no validation against `block.timestamp`. Combined with the DummyVerifier granting VERIFIED tier (10x rewards) for any non-empty proof, attackers can drain the token supply.

Issues Found

Severity	Count
High	3
Medium	4
Low	3
Informational	3
Gas	2
Total	15

Findings

High Severity

[H-1] User-Supplied unixDay Allows Complete Token Farm in Single Transaction

Description

The `recordMorningPage()` function accepts `unixDay` as a user-supplied parameter without validating it corresponds to the current day:

```
function recordMorningPage(
    uint256 unixDay,          // @audit User-controlled, no validation
    uint256 timestamp,        // @audit User-controlled, no validation
    bytes32 contentHash,
    bytes calldata proof
) external {
    uint256 journeyId = currentJourneyId[msg.sender];
    if (journeyId == 0) revert NoActiveJourney();
    if (unixDay == 0) revert InvalidUnixDay();
    if (morningPagesLog[msg.sender][journeyId][unixDay]) revert AlreadyLoggedToday();
    // @audit No check that unixDay == block.timestamp / 1 days
}
```

Impact

An attacker can call `recordMorningPage()` 84 times with sequential days and `recordArtistDate()` 12 times in a single transaction, earning all tokens and achievements instantly.

Test Output

```
[PASS] test_ExploitFarmEntireJourneyInOneTx()
Morning pages farmed: 84
Artist dates farmed: 12
Actual tokens earned: 20,950
EXPLOIT SUCCESSFUL - Entire 12-week journey completed in ONE transaction
```

Recommended Mitigation

```
function recordMorningPage(...) external {
    uint256 today = block.timestamp / 1 days;
    if (unixDay != today) revert InvalidUnixDay();
    if (timestamp > block.timestamp) revert InvalidTimestamp();
    if (timestamp < block.timestamp - 1 days) revert InvalidTimestamp();
}
```

[H-2] DummyVerifier Grants VERIFIED Tier (10x Rewards) for Any Non-Empty Proof

Description

The DummyVerifier grants VERIFIED tier for any non-empty proof:

```
function verifyWithTier(bytes calldata proof)
    external pure override
    returns (bool valid, VerificationTier tier)
{
    valid = true;
    if (proof.length == 0) {
        tier = VerificationTier.BASIC;    // 1x rewards
    } else {
        tier = VerificationTier.VERIFIED; // 10x rewards for ANY non-empty bytes
    }
}
```

Impact

Any user claims 10x rewards by passing `hex"01"` as proof:

- Morning pages: 10 → 100 tokens
- Artist dates: 50 → 500 tokens

Recommended Mitigation

```
function verifyWithTier(bytes calldata proof)
    external pure override
    returns (bool valid, VerificationTier tier)
{
    proof;
    return (true, VerificationTier.BASIC);
}
```

[H-3] Streak Manipulation via Out-of-Order Day Submission

Description

The streak calculation only checks if the gap between submissions equals 1. Submitting days 1-60 sequentially achieves all streak badges instantly.

Test Output

```
[PASS] test_ExploitInstantStreakAchievements()
Current streak: 60
Longest streak: 60
Tokens from streak badges: 1,200
Total tokens earned: 7,600
```

Recommended Mitigation

```
function _updateStreak(...) internal returns (uint256) {
    uint256 today = block.timestamp / 1 days;
```

```
    require(currentDay == today, "Can only log today");  
}
```

Medium Severity

[M-1] Global Content Hash Allows Front-Running to Deny VERIFIED Tier

Content hashes are stored globally, allowing attackers to front-run and steal another user's hash, downgrading them to BASIC tier.

Recommended Mitigation: Include user address in hash: `keccak256(abi.encodePacked(msg.sender, contentHash))`

[M-2] No Validation That `artistToken` Minter Is Set Correctly

If deployment doesn't call `artistToken.setMinter()`, all recording functions revert permanently.

[M-3] Artist Date Can Be Recorded for Future Weeks

All 12 artist dates recordable immediately = 6,000 tokens (VERIFIED).

Test Output

```
[PASS] test_ExploitFutureWeekArtistDates()  
    Current week: 1  
    Successfully recorded artist dates for weeks: 1, 6, 12  
    Tokens earned: 2,150
```

[M-4] External Call to Untrusted Verifier Before State Changes

External verifier called before state modifications. Add `ReentrancyGuard` for safety.

Low Severity

[L-1] **setVerifier Has No Zero Address Check**

[L-2] **TokenIds Library Uses require() Instead of Custom Errors**

[L-3] **Mixed Error Styles: Custom Errors vs revert() Strings**

Informational

[I-1] **Centralization Risk: Owner Can Record for Any User**

[I-2] **No Event for Streak Updates**

[I-3] **isProductionReady() Not Used in Main Contract**

Gas Optimizations

[G-1] **__isWeekComplete() Performs Redundant Storage Reads**

[G-2] **String Concatenation in Events Wastes Gas**

Proof of Concept Results

All vulnerabilities were verified with Foundry tests:

```
forge test --match-contract TokenFarmingExploit -vv
```

Test	Result	Impact Demonstrated
test_ExploitFRACEntireJourney20000	PASS	20,000 tokens in 1 tx
test_ExploitFRACStreakAchievements	PASS	60 elements streak instantly
test_ExploitFRACWeekArtistDates	PASS	4 weeks recordable day 1
test_ExploitFRACJourneyFarming	PASS	86,750 tokens across 5 journeys
test_ExploitFRACFixedTierForFree	PASS	40x rewards with hex"01"
test_CompareAttackerVsLegitimateUser	PASS	7x advantage over honest users

Projected Maximum Damage

Metric	Value
Per journey	~17,000 tokens
MAX_JOURNEYS	490
Single attacker potential	~8,500,000 tokens

Appendix

Tools Used

- Manual code review
- Foundry (forge test)

Files Reviewed

- ArtistWayJourney.sol (1079 lines)
- ArtistWayToken.sol (136 lines)
- DummyVerifier.sol (93 lines)
- IVerifier.sol (73 lines)
- TokenIds.sol (305 lines)

PoC Test File

- test/TokenFarmingExploit.t.sol